

Risk Management Standards - The Perception of ease of use

Piya Shedden

Department of Information Systems,
University of Melbourne,
Parkville, Victoria.

Dr. A. B. Ruighaver

2School of Information Systems,
Deakin University,
Burwood, Victoria.

Dr. Atif Ahmad

Department of Information Systms,
University of Melbourne,
Parkville, Victoria.

Abstract

Information security risk assessment has emerged as the primary means by which organizations secure information infrastructure. A number of risk management standards and methodologies, such as the AS/NZS 4360 and HB231 provide organizations with guidance on developing a risk assessment process. However, while there exists such high-level guidance, there is correspondingly little literature on the practice of conducting risk assessments. This paper presents the results of a case study undertaken as part of a larger investigation that examines the information security risk assessment processes implemented by organizations as well as the reasons for adopting them. This

research finds that organizations apply the high-level generic methodology outlined in the AS/NZS 4360 risk management standard due to a perceived ease of use. This research also finds that organizations simplify the risk methodology for the purposes of broad application across the organization. The process of simplification is achieved at the expense of the granularity of detail thereby reducing the depth at which the methodology is applied. The resulting outcome is a risk assessment methodology that no longer reflects the comprehensive nature of the original standard.

Keywords: Information security, risk management, risk assessment, risk management standards, information security guidelines

Introduction

Information technology (IT) expenditure has increased substantially in the past decade and organizations are fast recognizing the importance of information for their core business activities (Gerber & von Solms, 2005; Bandyopadhyay et al, 1999). There is subsequently an increasing awareness of the need for effective information security risk management processes to ensure the correct identification of information assets and risks and the selection and implementation of the most effective control strategies (HB 231, 2004).

The information security risk assessment process is a subset of the information security risk management process that establishes the organization's context, identifies information assets, threat and vulnerabilities, then assesses the impact and probability of threats occurring (Visintine, 2003; Roper, 1999), which will be examined later. This process is critical and needs to ensure that the correct information assets are identified for protection and that the correct risks are being protected against. Were these information security risk assessments not to occur, organizations would suffer potentially severe losses from external threats (eg. theft of confidential information, website defacement), internal threats (eg. fraud, user error) and other intangible effects (eg. a loss in organizational reputation).

In Australia, general risk management standards (eg. the AS/NZS 4360) and information security risk management guidelines (eg. the HB 231) have been released in an effort to establish a base process for conducting information security risk assessments. standards such as these have been constructed in order to provide an effective level of organizational information security through a best practice process (Waring & Glendon, 1998).

However, while there is literature on how organizations should conduct these assessments, there is little on how organizations actually do them. Additionally, there is not much literature on the applicability or usage of standards to facilitate a secure information environment. What literature that does exist states that standards are not widely recognized (KPMG, 2000), that they

take a great amount of expertise to apply (Halliday et al, 1996; Vigilinx, 2001) and that budget and resource constraints generally limit the implementation of the standards' processes (Lichtenstein, 1996; Gerber & von Solms, 2005).

Therefore, this paper will address these concerns by examining what information security risk assessment processes are currently being applied in organizations. Furthermore, this paper will also seek to understand organizational reasons for adopting and using particular methodologies. This paper will first discuss what comprises an information security risk assessment according to literature in order to uncover the precise series of phases and activities that organizations are advised to use in order to identify and assess their information security risks. The findings of a case study of an Australian organization (that was conducted in conjunction with two others) will then be presented, detailing what risk assessment process was actually used in the organization and whether it was a standard methodology. In this case study, ease of use was cited as being one of three major reasons that organizations adopted their information security risk assessment methodology. However, there exists a distinct difference between what the organization perceived and the reality in the organization, as the risk assessments were incomplete as a result.

INFORMATION SECURITY RISK ASSESSMENTS

The term 'risk' refers to the threat of loss of an organizational asset, incorporating the asset's value, its vulnerabilities and the range of threats to that asset measured in terms of probability and impact (ASIS International, 2002; Visintine, 2003; Frosdick, 1997; Peltier, 2000). An information security risk assessment is the staged process by which an organization's information assets are valued and where vulnerabilities and threats are identified so that they then guide the implementation and monitoring of control strategies and measures (Whitman & Mattord, 2005). They are critical for organizations to ensure the most effective and cost-efficient control strategies are selected, protecting the correct information assets from the correct threat and balancing the costs of these controls, the level of security provided and the access to the system by end-users (Roper, 1999).

There are different risk assessment processes, frameworks and methodologies in information security literature, yet in each exists the same underlying structure in varying levels of abstraction and granularity: the phases of context establishment, asset identification, threat identification, risk analysis and prioritization (Thorn, 2001; Whitman & Mattord, 2005; Visintine, 2003; Peltier, 2000, Roper, 1999) as demonstrated in Figure 1.

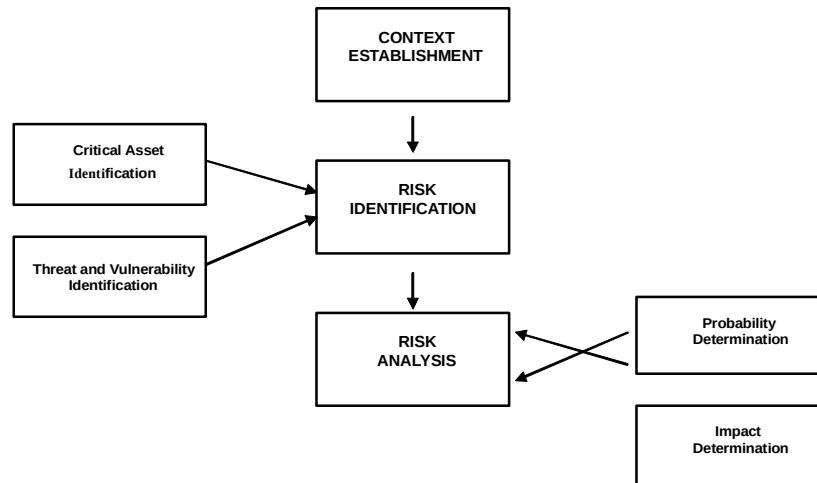


Figure 1 - the Risk Assessment Process

(Source: Thorn, 2001; Whitman & Mattord, 2005; ASIS International, 2002; Visintine, 2003; Peltier, 2000; Roper, 1999)

This process can be expressed qualitatively, using words and labels to denote importance and criticality (eg. 'high', 'medium' and 'low') or quantitatively, using statistical measures and equations to arrive at a numerical expression of asset value or a numerical risk rating (Visintine, 2003; Whitman & Mattord, 2005). Control selection and implementation, the monitoring and review of controls post-implementation and communication activities with stakeholders are critical phases of the overarching risk management process in addition to the risk assessment process discussed (AS/NZS 4360, 1999; Bandyopadhyay et al, 1999; ASIS International, 2002). However, these are not considered within the boundaries of the risk assessment process itself.

Context Establishment

The context establishment phase requires that the organization identify its operations, its property, its industry and its overarching strategy (ASIS International, 2002). Here, the organization develops an understanding of itself to appreciate its own complexities and nuances that may influence their information security environment and requirements. This phase examines the organization to determine if there are any industry-specific risks as well as any other issues that may impact the risk management process, or steer it down a particular path. Analyzing the organization ensures that the business

environment is known (business type, focus, departments, structure and customers) to align organizational goals with the goals of the information security risk assessment and to establish what risks may be present in each area of the organization to better scope and place boundaries on the risk management process to come (Halliday et al, 1996; Bandyopadhyay et al, 1999).

Risk Identification

This phase consists of two key sub-processes - critical asset identification and threat and vulnerability identification. Critical asset identification seeks to identify the information assets that are highly important or critical to an organization's day-to-day operations through various information-gathering techniques such as brainstorming, interviewing of key stakeholders, simulations, scenario consideration and organizational documentation reviews (Frosdick, 1997). Whilst the general definition of an asset is 'anything of value' to an organization (Visintine, 2003), information assets are defined more strictly as hardware, software, physical documents and procedures (HB 231, 2004). Here, assets should be assessed on their criticality to the overall function of the organization or their direct total value. They should ideally be ranked in order of importance according to a set scale using a quantitative (eg. asset loss exposure) or qualitative approach (Whitman & Mattord, 2005; Visintine, 2003; Roper, 1999).

After information assets have been identified and prioritized according to their importance to business operations and processes, the organization needs to identify the threats to those information assets and the vulnerabilities that exist within the assets (Visintine, 2003; ASIS International, 2002). Here, a vulnerability is defined as being an inherent weakness in an information asset that can be exploited, such as an open port connected to the internet or the use of unpatched software (Roper, 1999), whereas a threat is considered as any one of many general categories of events, objects or motivations that that can exploit that asset, such as malware (eg. viruses, Trojan Horses), theft from outsiders (eg. through hacking of systems by outsiders, or physical entry and trespass) and human error (Visintine, 2003; HB 231, 2004; Whitman and Mattord, 2005). The organization must identify what threats may impact the identified critical information assets and analyze them to determine what exploitable vulnerabilities exist given the current controls in place throughout the organization. The outcome of this phase is a list of threats to the critical information assets, given the vulnerabilities.

Risk Analysis

Risk analysis is the process by which the risks to the organization are measured in terms of consequence and likelihood (Roper, 1999). Here, the organization attempts to assign values to each risk, determining the probab-

ity of that risk occurring and the impact the risk would have on that information asset (and subsequently the business) if it were to occur. As mentioned, this can be performed through qualitative, quantitative or a combined method, using the knowledge and estimation powers of both the risk managers, key stakeholders, experts (such as the police) and other sources of information (Visintine, 2003).

Qualitative approaches to this process use descriptive words to signify the criticality of that risk. One of the most common methods by which to pursue qualitative risk analysis approaches is to use metrics such as those used in Roper (1999), Thorn (2001) or HB 231 (2004), as Figure 2 demonstrates:

Likelihood	Impact			
	Critical	High	Medium	Low
Almost certain	High	High	Medium	Low
Likely	High	High	Medium	Low
Moderate	High	High	Medium	Low
Unlikely	Low	Low	Low	Low

Figure 2 - Consequence and Likelihood Matrix
(Source: Roper, 1999; Thorn, 2001; HB 231, 2004)

Using this matrix, a 'likely' probability and 'high' impact measurement result in an overall 'high' risk rating. Therefore, this particular information asset would most likely require protective measures installed to control that risk. However, if a particular threat was 'unlikely' to occur, even with a 'high' impact criticality rating, the threat is typically deemed as not being worthwhile controlling. In practice, this may be a problem - risks with extremely high impacts are often mitigated nonetheless (Roper, 1999).

In contrast to the qualitative method, quantitative approaches use statistical and mathematical formulas to determine the importance of assets, threats and impacts, including the Expected Value Analysis and Annualized Loss Expectancy methods (Bandyopadhyay et al, 1999; Whitman & Mattord, 2005). To illustrate the numerical orientation of quantitative approaches, consider the Annualized Loss Expectancy formula, where:

$$\text{Annualized Loss Expectancy} = \text{Asset Value} \times \text{Exposure Factor} \times \text{Frequency (annual rate of occurrence)}$$

Here, Asset Value is the monetary value of the information asset, the Exposure Factor is a percentage value derived from an estimation of how exposed the asset is to a threat (eg. an asset is said to be at 50% exposure to a particular risk), and the Frequency of the risk's occurrence per year (Visintine,

2003). The output of this equation will be a certain sum of money suffered each year due to the identified risk. Based on this information, risks can then be prioritized to determine which can be accepted by the organisation (governed by the 'risk appetite' of the business) and which should be mitigated, taking into account the asset's value and the criticality of the risk (Halliday et al, 1996).

However, while literature does demonstrate how organizations should conduct their information security risk assessments, there has been minimal reporting on how organizations actually conduct their assessments. Their information security risk assessment processes, considerations, practices and activities are unknown, and therefore it is uncertain as to how effective organizational information security risk assessments are in providing and promoting a solid information security environment.

RISK MANAGEMENT STANDARDS

Therefore, in an effort to solidify best risk management practice in industry, risk management standards such as the AS/NZS 4360:1999 Standards and the recent HB 231:2004 Information Security Risk Management Guidelines have been developed by academic, governmental and industry representatives. These standards aim to deliver a high-quality, effective risk management process for organizations, providing a single, formal risk assessment process for organizations (Waring & Glendon, 1998). The AS/NZS 4360:1999 and HB 231:2004 share a common risk assessment methodology that is similar to that described above, incorporating context establishment, risk identification, risk analysis and risk evaluation.

Context establishment exists in much the same form as that phase discussed above, designed to outline the strategic context, organizational context and risk management context to ensure proper alignment with organizational strategy, objectives and goals, that any threats that emerge from the organization's industry and its environment are made known and that the risk management process is correctly scoped. It is also during the context establishment phase that risk evaluation criteria are outlined (ie. make decisions about what particular threats the organization can deal with and what can be ignored depending on operational, technical, financial, legal and social criteria), and asset identification is conducted.

Risks identification examines what can happen, how and why it can happen and what tools can be used to identify the risks the organization faces, including checklists, brainstorming and scenario analysis. Ideally, this phase should also integrate threat and vulnerability analysis of each asset to build as accurate a profile as possible on what may attack that asset, and through what security 'hole'.

Risk analysis, examines the existing controls within the organization and the subsequent consequences and likelihood of the risks occurring using either qualitative or quantitative techniques. Tables similar to Figure 1 are offered as a means of doing this qualitatively, or substitution of 'high', 'medium', 'low' values for numerical representations in order to establish a quantitative level of risk.

Risk evaluation is the final phase, where the organization compares the result of the risk analysis (ie. the risks found that may impact the organization's information security) with the risk evaluation criteria from the context establishment phase. Organizational criticality ratings are assigned to outline the priority with which risks to treat immediately according to that set criteria, which risks can be treated at a later date, and which risks can be ignored.

In addition to the AS/NZS 4360 Standard, the HB 231 Guideline has been developed to provide further details pertaining to information security information security risks. The Guideline applies the same underlying methodology as the AS/NZS 4360 Standard, but tailors it towards the information security field by providing relevant examples of information security assets and information security threat types. On a related note, there also exists a companion Standard to those outlined above - the AS/NZS ISO/IEC 17799:2001 code of practice for information security management. This Standard was produced to guide managers and employees responsible for information security management by providing them with a comprehensive, extensive list of information security considerations (AS/NZS 17799, 2001). While not directly applicable to the general and information security risk management Standards and Guidelines, it assists in managerial decision-making on information security within the organization.

Issues in the Application of Risk Management Standards

However, little literature exists on the effectiveness of risk management standards when applied in organizations, or their applicability to information security risk assessment methodologies created or applied in industry. While it is known that organizations are becoming much more risk-aware (Scott, 2002), there is also evidence that many organizations have not developed formal risk assessment methodologies despite the emergence of these standards and guidelines some time ago (KPMG, 2002). This raises questions regarding the potency of risk management standards and how organizations perceive their usefulness.

There are also inherent issues in the use of such baselines - standards and guidelines contain many hidden complexities and nuances that, whilst appearing user-friendly and simple on the surface, can actually confuse or overwhelm risk managers (Halliday et al, 1996). This is problematic - if orga-

nizations do not understand these subtleties, a high-level risk assessment process will be the result and specific assets and risks will not be identified, providing poor risk assessment outputs (that is, an inferior level of information security). In order to effectively apply the standards, it is therefore necessary to possess a great deal of expertise on the part of the assessor regarding risk, risk assessments and the standards, possibly requiring extensive training and the involvement of a large number of experienced staff in order to make good use of that formal methodology (Halliday et al, 1996).

Standards and guidelines also still suffer from the problem of subjectivity (Lichtenstein, 1996). This is not only constrained to risk analysis phases, but also to the interpretation of the standards and guidelines themselves and their translations to the organizational context. This issue concerns how the standards are understood by the assessors, and how the methodology is applied to the organization. If an incorrect interpretation was made of any part of the standards, the result of the risk assessment could be inaccurate and produce a flawed picture of the organization's information security risks.

Therefore, in light of these issues, an exploratory study is required to determine whether risk management standards are applied in industry and to what extent in order to understand the organizational motivations for applying standards, to examine how they are used and applied and to determine how successful these standards are in providing adequate information security coverage.

RESEARCH DESIGN

The case study research methodology was selected for use in this research project, as it is well-suited for understanding IT- and IS-related factors and for studying information systems in the field (Shanks et al, 1993; Cavaye, 1996). Information security risk assessment is also a dynamic and not yet mature area of IS research, where again case studies prove to be highly effective (Darke et al, 1998), particularly as the aim is to gather a great amount of rich information (Galliers, 1991; Shanks et al, 1993). The exploratory research purpose was selected in order to become familiar with these opinions and reasons, as it is this research methodology that aims to explore a new phenomena or situation that little has been written about (Neuman, 2003). Qualitative data was collected in the forms of words, pictures, diagrams and documents as it is the more appropriate form for exploratory studies.

A total of three organizations were selected to better draw out common themes and issues. While only one case study is presented in this paper, the remaining two featured the same predominant themes as those outlined here. These organizations were selected passively - in security research, organizational interest or willingness to participate is difficult to obtain. In the

context of this research project, selection therefore needed to be based upon which organizations were available to the researcher. However, general traits did serve to differentiate the acceptability of those organizations that demonstrated interest - their size, technical capability, security knowledge and their understanding of standards throughout the business and their industry.

For this project, Organization A (names have been changed to preserve anonymity) was ideal in that it was a large Australian utility services company with defined information security frameworks and methodologies. Data was collected in the form of two semi-structured interviews in January 2005 and was bolstered with the addition of substantial documentation on the organization's information security risk assessment policy, presentations and frameworks. Specifically, two participants were interviewed in Organization A - the chief information officer (Participant 1) who is responsible for the success of the information security risk assessment process and the business analyst responsible for the marketing, implementation and operation of the information security risk assessment process (Participant 2).

The interviews were recorded at the participant organization with permission and transcribed to ensure a thorough analysis of all answers and that all relevant concepts could be brought to attention. In information security research, documentation is extremely difficult to receive from the participant organizations, yet the participants in Organization A provided the researcher with ample documentation on the organization's risk assessment methodology for removal off-site for later analysis, as well as presentation materials and organizational policies for analysis during the interview and as an item for discussion and questions. This documentation was extremely useful for the triangulation of participant comments and provided further background and information to build a rich picture of the organization's information security risk assessment process.

These interview transcripts and documents were then analyzed through three iterations to fully comprehend the rich qualitative content and to ensure that the correct concepts and issues are accurately drawn out. The first pass outlined the initial broad themes and categories, resulting in an initial report that summarized the selected quotations and their meaning. The next focused on these existing themes, looking for categories that clustered together, resulting in another document written on each theme with more detail and their relations to the other themes. The final pass identified the major concepts of the project, distilling the detail down to several specific quotations and examples that validated the core themes and ideas as represented in the data. The output of this process was a final document that highlighted these themes in a format that would propose a solution to the issues articulated previously.

THE INFORMATION SECURITY RISK ASSESSMENT PROCESS

The first concern to be addressed was the determination of how organizations conduct information security risk assessments; that is, the process or series of phases and activities that address context establishment, risk identification and risk analysis. The findings demonstrate conclusively that Organization A's information security risk assessments are based upon the AS/NZS 4360:1999 Standard. Organization A has formally constructed their information security risk assessment process within the last year in accordance with the AS/NZS 4360 Standards, using elements of the AS/NZS 17799 Standards in addition to the company-wide process for conducting risk assessments.

Organization A firstly sought to establish the information security risk assessment context by examining the goals, objectives, strategies, scope and parameters of the activity that is under scrutiny, according to the Procedure for the Management of Business Risk document provided by Organization A. To do this, the organization has adopted the AS/NZS 17799 Standard to provide checklists on existing controls and identify the gaps in the organization's current information security coverage. In an effort to understand how organizations conduct information security risk assessments, the interview transcripts and the organizational documentation provided served to describe their processes through the standard's process of context establishment, risk identification and risk analysis.

Context Establishment

According to the AS/NZS 4360's process, context establishment should be the first concrete phase in the organization's risk assessment in order to consider the organization's environment, industry, to set the scope for the risk assessment that takes place and to identify information assets. Organization A first seeks to establish the information security risk assessment context by examining the goals, objectives, strategies, scope and parameters of the activity that is under scrutiny, according to the organization's Procedure for the Management of Business Risk documentation. However, the organization achieves this by using the AS/NZS 17799 Code of practice to establish the context, mixing in the evaluation of existing controls and those open risks (or risks which have not been controlled). Here, the 17799 Code of practice is used to generate a large 'checklist' detailing the controls that the organization should have already implemented - in other words, Organization A conducts a gap analysis of their security environment for the systems in-scope, using a series of tables and checklists for the purpose.

Assets are identified at a high level of granularity, with information systems being understood as assets. The involvement of systems administrators and end-users are understood as being critical for this process as they

are the most knowledgeable of the systems and processes. Historical information and the results of Business Continuity Planning (BCP) simulations are factored in to understand which systems are the most critical for the ongoing support and operations of the organization.

Risk Identification

The Standard's process for risk identification involves the systematic review of the relevant areas of the organization to build a comprehensive list of risks through checklists, flowcharts, brainstorming, structured interviews and simulations. Documentation from Organization A states that the risk identification process is aimed at investigating and documenting all adverse outcomes for the organization, involving commercial relationships, compliance obligations, human behavior, and technological change.

On the actual activities that are performed to find threats and vulnerabilities, Organization A's risk identification phase is blended with context establishment as previously mentioned. The interview participants identified that their risk identification process is performed through the use of those checklists built from the AS/NZS 17799 Standard. These checklists identify where controls currently exist in the organization's information systems and environment and which areas of the organization are therefore left open for attack (ie. which areas have no controls or strategies in place to mitigate, transfer, avoid or reduce information security risks) in their current information security coverage. The organization uses these checklists to consult with appropriate staff, systems administrators and historical records to 'fill in the blank spaces'. This establishes the general areas in which the organization lacks controls.

However, this is not the AS/NZS 4360 Standard process being applied here. Rather, the organization's use of the 17799 Standard amounts to a gap analysis of the organization's existing controls. This does not consider the organization's information security requirements, but rather only the general configuration of those controls present in the organization. It does not proactively identify the threats to each critical information asset, nor the specific vulnerabilities for each asset.

Risk Analysis

Risk analysis is a process defined in the standards where consequence and likelihood are evaluated in order to produce an overall, measured level of risk for each particular threat event that could occur. For Organization A, risk analysis is conducted using the organization's risk-scoring matrix derived from the 4360 Standard appendices, where personal yet informed values are applied to rate consequence and likelihood.

From documentation and participant comments, the risk analysis phase is run on two levels - one involving 'inherent' risk, where existing controls are ignored to build a picture of those risks which are strategically important to the organization, and the 'residual' risk, which does factor existing controls to establish how much risk remains. The risk analysis matrix used is based upon an organization-wide model, used to evaluate other forms of risk as well as information security.

Specifically, the matrix used to determine the level of information security risk details Occupational Health and Safety (OHS) risks (eg. personal injury is described as a risk) and the interview participants discussed the risks in those terms. The risk analysis is qualitative, with probability ratings from 'rare', where the event is described as only occurring in exceptional circumstances, to 'almost certain'. Consequence ratings range from 'insignificant', with 'no injuries or low financial loss', up to 'catastrophic', which is described in terms of 'fatality, toxic release off-site, huge financial loss'. Both ratings are combined in the matrix to produce an overall level of risk. The organization then prioritizes the risks based on the overall result of this analysis. However, while this process is in line with the 4360 Standard, these OHS ratings were discussed by participants as those measures actually used in the information security risk assessment. This is not appropriate to information security risks, and at the very least, these labels need to be altered to more accurately reflect the impacts of information security risks.

THE PERCEPTIONS AND REALITY OF EASE OF USE

Given this process, it was stated by the participants that the organization applied the AS/NZS 4360 Standards and derived this risk assessment process from its contents primarily for its ease of use. Two other factors were also cited by the three participant organizations (ie. that using the standards allows the organization to achieve certain non-security-related outcomes and that the general risk standards ensure a consistent process throughout the organization) but these are not considered in the context of this article.

It was believed that ease of use was an excellent draw card and good motivation for using risk management standards and one of the predominant reasons that they should be applied in organizations, as discussed by Participant 1, Organization A:

P1, Org A: I think they're relevant for what they're looking for. I think what any standard gives you is a common baseline and from what I see a functional baseline to design our risk standards and policies around.

I: Why do you believe that?

P1, Org A: Because of that broader business use and I think because

they were simple enough for us to implement within our business context.

Therefore, there is the belief that using the AS/NZS 4360 Standard was easy and simple to implement and apply within the organization due to its structured content and the wealth of information it provided that could assist with its application. However, there exists a very distinct difference between the organization's perception of the AS/NZS 4360's Standard's ease of use and the reality within the organization.

However, despite the initial belief that the organization applies the Standard accurately, Organization A actually uses a simplified risk assessment process that is a summary of the AS/NZS 4360 Standard methodology, as Participant 2 stated:

P2, Org A: We do have a business-wide procedure which really just summarizes the approach of the Standard and tailors it to <Organization A> so... It's nothing, it's not rocket science - a lot of it's just really summarizing the Standard.

In short, the participant stated that the organization is applying a business-wide process for their information security risk assessments that itself is a summary of the AS/NZS 4360 Standard. Analysis of the organizational documentation further illustrates this. This company-wide policy is used as the basis for conducting all forms of risk assessments across the organization and consists of a brief, high-level description of each phase of the AS/NZS 4360 Standard process (the phases of context establishment, risk identification, risk analysis and risk evaluation). This is accompanied by the aforementioned qualitative risk analysis table that is used to determine probability and impact in terms of OHS risk events rather than information security-specific consequences. It is this document that forms the fundamental basis for the information security risk assessments, as reported by the interview participants.

However, the initial perception that the Standards are easy to use is inaccurate as it is not the Standards that are being considered or judged as simple. Instead, the participants' judgments are instead based upon the simplified, broad and general process that has summarized the Standard methodology in a brief document containing broad descriptions of the process activities that detail, at a high level, what is required for each phase. This brings the complexity of the Standards and the resources required for an information security risk assessment back to a simpler level, otherwise the implementation of the Standard process as-is would be too difficult, as discussed by Halliday et al (1996).

The fact that the Standard's process has been simplified in such a manner also implies that the Standard itself is not easy to understand and is not simple to use, despite the beliefs put forward by the organization. How-

ever, in simplifying the Standard methodology, a great number of the Standard processes (eg. establishing of risk management, organizational and strategic context, the appropriate standard process for identifying risks, etc) are lost or altered and the risk assessment process and its process outcomes and results therefore become much more high-level and generalized. The fact that this standard has required simplification and that the interview participants have specifically outlined that their information security risk assessments are based on these 'reduced' documents strongly state the case that risk management standards are not easy to use. Rather, they are complex and require a great deal of understanding and knowledge in order to implement effectively, with full understanding and recognition of its nuances and subtleties.

Unfortunately, this simplification and the generalization of each phase of the Standard's risk management process has lead to significant problems present in the organization's risk assessment process - specifically within context establishment and risk identification. The context establishment phase, as outlined previously, should identify the organizational, strategic context and risk assessment context. Organization A uses the AS/NZS 17799 Standard for both context establishment and risk identification. As stated by the participants, the AS/NZS 17799 Standard was viewed as the 'criteria' for an information security risk assessment, whereas the AS/NZS 4360 Standard is the 'calculator'. However, the usage of the AS/NZS 17799 Standard in this manner goes against the intentions of both standards - the AS/NZS 4360 is indeed the process that must be followed, but the AS/NZS 17799's focus is instead on providing comprehensive recommendations to assist in the development of security practices, not to be reduced and used as a checklist for information security risk assessment (AS/NZS 17799, 2001). Organization A's usage of this standard amounts to a gap analysis of the current organizational environment, but it is not explicitly establishing the organization's context, its strategic objectives and the boundaries of the information security risk assessment as is required.

Furthermore, the use of the AS/NZS 17799 Code of practice does not proactively identify risks inherent to each information asset - rather, the checklist built from the AS/NZS 17799 Standard is a broad list of areas of concern at a system-wide or organization-wide level. This is not the AS/NZS 4360 Standard process for conducting risk assessments despite claims to the contrary. Instead, this only identifies general controls that have not been applied and those generalist risks that may occur as a result. Though this does identify where current controls exist in the organization's information environment, this very high-level overview of the organization is too broad and does not consider specific threats to specific assets, nor the actual vulnerabilities of these assets as should be done. Therefore, there is the strong possibility that threats specific to individual information or information systems assets will pass undetected.

Additionally, the issue of simplification also impacts the granularity in identifying assets for protection and subsequently impacts the threat and vulnerability assessments of the process. The summarized document does not mention asset identification, leading the organization towards adopting the idea that the 'system is an asset'. This idea of the 'system as an asset' does not lead to an effective information security risk assessment. Assets must be identified at a more in-depth level of granularity, else again one will not be able to identify the correct threats and vulnerabilities that each individual asset is susceptible to and security coverage will hence suffer (Whitman & Mattord, 2005; Peltier, 2001).

Therefore, the simplification of the AS/NZS 4360 Standard contributes to a non-standards-based process for the identification of threats and risks. The Standard's methodology outlines that threats and vulnerabilities that should be determined through brainstorming sessions, expert opinions and stakeholder discussions (AS/NZS 4360, 1999). However, for Organization A, threat and vulnerability identification comes about through the gap analysis with the use of the 17799 Standard, with stakeholders and others contributing to a predefined list of risks and controls. There is no clear indication for Organization A that threats and vulnerabilities are specifically identified for each critical asset as should be done, rather than just considering the broad risks. It is important to know which specific controls should be selected to mitigate what specific risks, knowing what the asset's vulnerabilities are to ensure the most cost-effective solution is applied, and the most wholesome control strategy and mechanism.

CONCLUSION

Due to the recognition of the importance of general and information security risk management, formal standards and guidelines have been released that detail a base process for risk assessments and seek to establish a methodology to ensure a good level of security awareness and protection in organizations. However, while IS and information security literature does describe how organizations should conduct information security risk assessments in detail and articulates its importance, little is actually known about how organizations conduct these assessments in the field. Furthermore, there is little evidence on how useful these general and information security risk management standards and guidelines actually are, or indeed if they are used at all.

In order to better understand these areas, this paper has discussed the results of one of three exploratory case studies in Australia. These case studies have demonstrated how organizations conduct their information security risk assessments, and their reasons for conducting them in that particular manner. This has also enabled the exploration of how widespread the

adoption of standard methodology adoption is, how they contribute to information security risk assessments and to discern what the organizational perceptions are on the applicability and usefulness of these risk management standards and guidelines.

It was found that the organization (along with the two others studied) used the AS/NZS 4360 general risk management Standards as the basis for their information security risk assessments. That is, they attempted to engage top-management support, establish their organizational, strategic and risk assessment context, identify the risks and conduct a risk analysis. However, it was also found that there existed a difference between the organizational perception of the standards and the reality of their risk assessment process.

One of the primary reasons for the adoption of the risk management Standards was its perceived ease of use and application - the organization believed that the Standard contained simple to implement within its business content. However, upon further analysis it became evident that the organizations actually use a high-level, general risk assessment process for information security risk assessments that is a brief summary of the standard. Therefore, the perception of ease of use is inaccurate, firstly because the organization is basing its perception of the simplicity of the Standard on the this brief, summarized organization-wide policy. Furthermore, the fact that organizations require this high-level summary, and that this summary is directly used for conducting information security risk assessments presents a strong case that standards themselves are too difficult to comprehend and understand, and require this simplification in order for risk assessors to grasp the standard's concepts.

Unfortunately, this simplification has also led to less-than-desirable security outcomes: critical phases such as context establishment, asset identification and threat identification are not conducted as required by the AS/NZS 4360 Standard. This has resulted in the reduction of the context establishment phase to a gap analysis of the organization and a very high-level, broad identification of assets and threats.

REFERENCES

- ASIS International. (2002). The General Security Risk Assessment Guidelines, ASIS International, Alexandria, Virginia, USA.
- AS/NZS 4360. (1999). Risk management, Sydney, Australia/ Wellington, New Zealand. Standards Australia/ Standards New Zealand.
- AS/NZS ISO/IEC 17799. (2001). Information technology - Code of practice for information security management, Sydney, Australia/ Wellington, New Zealand. Standards Australia/ Standards New Zealand.

- Bandyopadhyay, K., Mykytyn, P.P. and Mykytyn, K. (1999). 'A framework for integrated risk management in information technology', *Management Decision*, 37 (5): pp.437-444.
- Cavaye, A. (1996). 'Case Study Research: a multifaceted research approach for IS', *Information Systems Journal*, 6: p.227-242.
- Frosdick, S. (1997). 'The techniques of risk analysis are insufficient in themselves', *Disaster Prevention and Management: An International Journal*, 6 (3): pp.165-177.
- Galliers, R.D. (1991). 'Choosing Information Systems Research Approaches' in *Information Systems Research: Contemporary Approaches and Emergent Traditions*, eds H-E. Nissen, H.K. Klein and R.A. Hirschheim, Proc. IFIP TC8/WG8.2 Working Conference, Dec. 1990, North Holland.
- Gerber, M. and von Solms, R. (2005). 'Management of risk in the information age', *Computers and Security*, 24: pp.16-30.
- Halliday, S., Badenhorst, K., von Solms, R. (1996). 'A business approach to effective information technology risk analysis and management', *Information Management and Computer Security*, vol.4, no.1, pp.19-31.
- HB 231. (2004). *Information security risk management guidelines*, Sydney, Australia/ Wellington, New Zealand. Standards Australia/ Standards New Zealand.
- KPMG. (2000). *Risk Survey Report*, KPMG, Canada.
- Lichtenstein, S. (1996). 'Factors in the selection of a risk assessment method', *Information Management and Computer Security*, 4 (4): pp.20-25.
- Neuman, W.L. (2003). *Social Research Methods - Qualitative and Quantitative Approaches*, Allyn and Bacon, United States of America.
- Peltier, T. (2000). *Information Security Risk Analysis*, Auerbach Publications, United States of America.
- Roper, C.A. (1999). *Risk management for security professionals*, Butterworth-Heinemann, United States of America.
- Scott, J. (2002). *Risk management survey*, PricewaterhouseCoopers, United States of America.
- Shanks, G., Rouse, A. and Arnott, D. (1993). 'A Review of Approaches in Research and Scholarship in Information Systems', *Proceedings of the 4th Australian Conference on Information Systems*, Brisbane, pp.29-44.
- Thorn, M.E. (2001). 'Applications of technology and risk management', *S.A.M. Advanced Management Journal*, 66 (4): pp.4-14.
- Vigilix. (2001). *Security Assessment Methodology*, Vigilix Digital Security Solutions, Parsippany, New Jersey, USA.
- Visintine, V. (2003). *An Introduction to Information Risk Assessment*, SANS Institute.
- Waring, A. and Glendon, A.I. (1998). *Managing Risk*, International Thomson Business Press, London, UK.
- Whitman, M.E. and Mattord, H.J. (2005). *Principles of Information Security*, Thomson Course Technology, United States of America.

AUTHOR BIOGRAPHIES

Piya Shedden graduated with his Bachelor of Information Systems (Honors) degree in 2005 from the University of Melbourne's Department of Information Systems. He is currently a PhD student and research assistant at

the university. His current research interests include information security risk assessment methods, processes and standards, incident response and securing knowledge assets.

A. B. Ruighaver is a research fellow at the School of Information Systems, Deakin University. Starting his academic career as a physicist developing parallel computers with optical interconnections, his research over the past decade has concentrated on Computer forensics and information security. Current research interests are in the areas of wireless intrusion detection, forensic investigations, information security risk assessment, security governance and security culture.

Atif Ahmad maintains a research and professional profile in cyber security. He is a founding member of the Organizational and Information Security Research Group at the University of Melbourne. Atif currently works with a number of local and international consulting groups in the area of information security. He has been involved in various cyber security assessment projects for IT companies and critical infrastructure operators. Atif is a Certified Protection Professional with ASIS.